

Plan d'action sécurité : les 30 premiers jours

VerroulA · Kit de protection · septembre 2026

Un mois pour verrouiller l'essentiel de votre entreprise : quatre semaines, quatre chantiers. Vous n'avez pas besoin d'être technicien : chaque action est décrite simplement, avec le responsable, le temps nécessaire et la priorité. Réservez quatre créneaux fixes d'une à deux heures, idéalement le même jour de chaque semaine.

Comment utiliser ce plan

- Lisez la semaine en entier avant de commencer : certaines actions se préparent à l'avance.
- Tenez le rythme. Une semaine de retard se rattrape ; un plan abandonné ne protège rien.
- Dans une TPE, le dirigeant est souvent le référent. S'il existe un salarié plus à l'aise avec les outils numériques, désignez-le référent sécurité et gardez la décision finale.
- Les durées sont données pour une entreprise d'un à dix postes informatiques. Adaptez-les à votre taille, sans supprimer d'étape.
- Les priorités : critique signifie à faire avant tout ; haute signifie dans la semaine ; moyenne signifie la semaine suivante au plus tard si le temps manque.
- À la fin de chaque semaine, notez la date de réalisation de chaque action. C'est votre preuve d'avancement.

Semaine 1 : mots de passe et double authentification

Objectif : plus aucun compte professionnel clé ne se protège par un simple mot de passe.

1. Faire l'inventaire des comptes professionnels. Qui : dirigeant ou référent. Durée : 45 minutes. Priorité : critique. Listez sur une page tous les comptes utilisés pour le travail : messagerie, banque, hébergement, nom de domaine, cloud, logiciels, réseaux sociaux, espaces fournisseurs. Notez pour chacun qui l'utilise et qui en est propriétaire.
2. Créer le coffre de mots de passe de l'entreprise. Qui : dirigeant. Durée : 30 minutes. Priorité : critique. Ouvrez un compte sur un gestionnaire de mots de passe reconnu, créez le coffre professionnel et enregistrez-y les identifiants principaux. Plus aucun mot de passe clé ne reste dans un fichier ou sur un pense-bête.
3. Changer les mots de passe des comptes administrateurs. Qui : dirigeant. Durée : 30 minutes. Priorité : critique. Pour chaque service principal, le compte propriétaire ou administrateur reçoit un mot de passe unique d'au moins 12 caractères, généré par le coffre.
4. Activer la double authentification. Qui : référent avec le dirigeant. Durée : 60 à 90 minutes. Priorité : critique. Commencez par la messagerie, puis la banque, puis les comptes administrateurs. Suivez la procédure proposée par chaque service et notez la méthode retenue dans le coffre.
5. Planifier la revue trimestrielle des accès. Qui : référent. Durée : 10 minutes. Priorité : moyenne. Ajoutez au calendrier un créneau trimestriel de 30 minutes pour vérifier qui accède à quoi.

Semaine 2 : les sauvegardes 3-2-1

Objectif : vos données existent en trois copies, dont une hors site, et la restauration a été testée une première fois.

1. Identifier les données vitales. Qui : dirigeant. Durée : 45 minutes. Priorité : critique. Messagerie, fichiers clients, comptabilité, contrats, données commerciales, dossiers RH. Décidez ce qui mérite trois copies et ce qui peut se perdre sans arrêter l'activité.
2. Installer le premier support de sauvegarde. Qui : référent. Durée : 60 minutes. Priorité : critique. Un disque dur externe dédié à la sauvegarde. Lancez une première sauvegarde complète et vérifiez le rapport.
3. Mettre en place la copie hors site. Qui : dirigeant pour le choix, référent pour l'installation. Durée : 60 à 90 minutes. Priorité : critique. Un service de sauvegarde en ligne professionnel et chiffré, avec sauvegarde planifiée. Enregistrez les identifiants dans le coffre et activez la double authentification sur ce compte.
4. Fixer le créneau hebdomadaire et nommer le référent sauvegarde. Qui : dirigeant. Durée : 15 minutes. Priorité : haute. Un jour fixe, une personne nommée, deux minutes de vérification à chaque fois.
5. Tester la restauration. Qui : référent. Durée : 30 minutes. Priorité : critique. Restaurez trois fichiers pris au hasard depuis chaque support et vérifiez qu'ils s'ouvrent. Ouvrez le tableau de suivi fourni dans la procédure de sauvegarde 3-2-1 et notez le résultat.

Semaine 3 : sensibilisation au phishing et procédure d'incident

Objectif : chaque salarié sait reconnaître un piège et, surtout, sait quoi faire s'il est tombé dedans.

1. Présenter la règle d'or de la vérification. Qui : dirigeant. Durée : 30 minutes de réunion. Priorité : critique. Tout message demandant de l'argent, des identifiants ou un acte inhabituel se vérifie par un autre canal : appel sur un numéro connu, visite au bureau, page officielle.
2. Montrer les formes d'attaques actuelles. Qui : dirigeant ou référent. Durée : 30 minutes. Priorité : haute. Usurpation du dirigeant, faux fournisseur et changement de compte bancaire, codes QR piégés, voix imitée par IA. Utilisez le guide double authentification et anti-phishing du kit comme support de réunion.
3. Diffuser la procédure « un salarié a cliqué ». Qui : dirigeant. Durée : 15 minutes. Priorité : critique. Prévenir dans l'heure, changer les mots de passe, alerter la banque sous 48 heures en cas de doute, consigner l'incident. Affichez la version courte dans l'espace commun.
4. Préparer les coordonnées d'urgence. Qui : référent. Durée : 15 minutes. Priorité : haute. Une page unique avec : numéro du service fraude de la banque professionnelle, contact de l'assureur, coordonnées du support de vos outils, coordonnées des autorités de signalement. Affichez-la près des postes de travail.
5. Organiser une première simulation annoncée. Qui : dirigeant. Durée : 30 minutes. Priorité : moyenne. Envoyez un faux message interne demandant un mot de passe ou un paiement, puis débriefez collectivement, sans sanctionner personne.

Semaine 4 : charte IA et revue des accès

Objectif : l'usage de l'intelligence artificielle est encadré, et les droits d'accès correspondent aux personnes réellement en poste.

1. Faire signer la charte d'utilisation de l'IA. Qui : dirigeant. Durée : 20 minutes. Priorité : haute. Chaque salarié lit la charte et signe l'engagement. Classez les originaux dans les dossiers individuels.
2. Vérifier les points de contact IA de l'entreprise. Qui : dirigeant. Durée : 30 minutes. Priorité : haute. Si un chatbot ou un assistant automatisé est en contact avec des clients ou des visiteurs, la mention d'information exigée par l'article 50 du règlement (UE) 2024/1689 doit être visible et à jour. Rappel : cette obligation s'applique depuis le 2 août 2026.
3. Établir la liste des outils d'IA autorisés. Qui : dirigeant. Durée : 20 minutes. Priorité : haute. Une page : outils autorisés, règle « rien sans accord », rappel des usages interdits. Demandez à l'équipe quels outils elle utilise déjà et tranchez.
4. Réviser la liste des accès. Qui : référent avec le dirigeant. Durée : 45 minutes. Priorité : critique. Comparez la liste des salariés et la liste des comptes ouverts. Désactivez les comptes des départs non supprimés, retirez les accès devenus inutiles, changez les mots de passe des comptes partagés.
5. Archiver et programmer la suite. Qui : référent. Durée : 20 minutes. Priorité : moyenne. Classez le kit, les tableaux de suivi et les accusés de réception. Programmez le test de restauration trimestriel et la revue trimestrielle des accès. La sécurité n'est pas un projet ponctuel : c'est un rythme.

Ce que vous obtenez au bout de 30 jours

- Plus aucun compte clé sans double authentification, et des mots de passe uniques rangés dans un coffre.
- Vos données en trois exemplaires, dont une copie hors site, avec une première restauration testée.
- Une équipe qui connaît les pièges de l'année et la procédure à suivre en cas de clic malheureux.
- Un usage de l'IA encadré, signé de tous et conforme à l'obligation de transparence du règlement européen.

La suite tient en deux rendez-vous trimestriels : le test de restauration des sauvegardes et la revue des accès. Ajoutez une session annuelle de sensibilisation au phishing. Avec ce rythme, votre entreprise reste verrouillée sans y passer vos journées.

En résumé

- Une heure et demie par semaine pendant un mois suffit pour verrouiller l'essentiel d'une TPE ou d'une PME.
- Semaine 1 : mots de passe et double authentification. Semaine 2 : sauvegardes 3-2-1 testées. Semaine 3 : équipe sensibilisée et procédure d'incident connue. Semaine 4 : charte IA signée et accès révisés.
- Chaque action indique qui la réalise, en combien de temps et à quelle priorité.
- Après le mois, deux rendez-vous trimestriels suffisent : test de restauration et revue des accès.